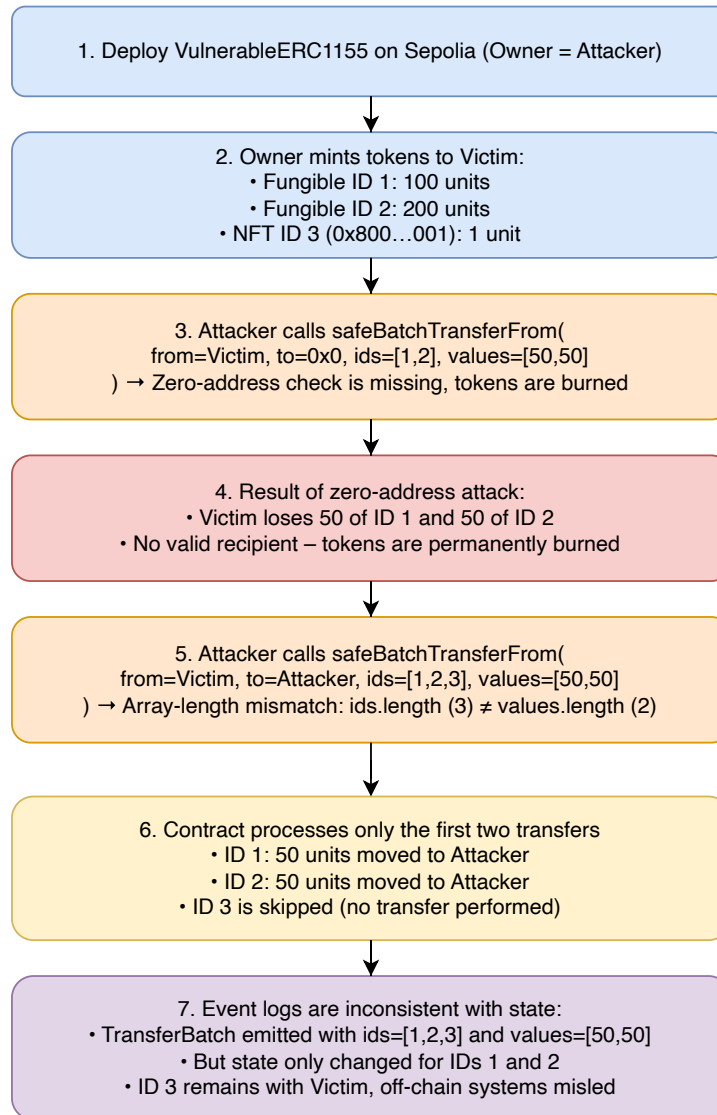


Batch Transfer Exploit – VulnerableERC1155



Why the attack works

Root Cause 1: Missing `require(to != address(0))` – allows sending assets to the zero address, effectively burning them.

Root Cause 2: Missing `require(ids.length == values.length)` – the contract does not enforce equal array lengths, so it processes only the first `values.length` transfers, skipping extra IDs. The emitted event is misleading, and the skipped tokens remain locked or unmoved, causing off-chain accounting errors.

Security Lesson: Always validate inputs (including address checks and array lengths) before performing any state changes. Ensure event emissions accurately reflect actual state modifications.

Observed Proof in the Demo

- Zero-address call succeeded: Victim's balances for IDs 1 and 2 decreased by 50 each; no recipient balance increased.
- Mismatched array call succeeded: Only IDs 1 and 2 were transferred (50 each) to Attacker; ID 3 remained with Victim.
- `TransferBatch` event emitted with `ids=[1,2,3]` and `values=[50,50]` – event logs do not match the actual state changes.
- No revert occurred despite the length mismatch, confirming the vulnerability is exploitable.